MVP hardening report

Takudzidza by Taku. 5 November 2026. For Takunda.

All 18 items are built and pushed to main as commit `a54d2f6`. Nothing is deployed. Production is still running the old version, and its settings were not touched. Every check passed on the final code in mock AI mode: lint, typecheck, 250 unit and backend tests, the build, and 40 browser journeys on a phone size and a desktop size.

Mock mode is the limit of this proof. No real AI model, email, text message, Google sign in or Sentry was called. So the features are proven to work with recorded replies and stand in senders, and how they behave with the real services is still unknown.

Before you deploy

New learners under 18 cannot finish guardian consent until a text message provider is added. You asked for consent to complete only with a phone code, and for the real provider to stay unconfigured. Together those mean the guardian's page says permission by text message is not switched on yet, and the learner stays waiting. Learners whose consent is already given are not affected. So you either add a provider first, or accept that the app is adults only for now.

The daily caps are very tight. The learner cap defaults to USD 0.05 a day, a number I assumed and did not measure. The deployment cap stays at USD 0.50 a day for everyone together. Set both before learners arrive. Production's old `LEARNER_DAILY_AI_CALLS` setting is ignored once this version is deployed.

What you need to add

Item	Until you add it	What to do
Text message provider for guardian codes. Blocks under 18s.	New under 18s cannot finish consent.	Choose a provider that reaches Zimbabwe. A developer then implements `SmsSender` in `convex/accounts/sms.ts`. It needs code as well as a key.
Resend: `RESEND_API_KEY`, `EMAIL_FROM`	Sign up works with no email check, and nobody can reset a password. Forgot password is hidden.	Create a Resend account, verify a sending domain, and set both on Convex. Without a verified domain, the default sender only reaches the Resend account's owner.
Google sign in: `AUTH_GOOGLE_ID`, `AUTH_GOOGLE_SECRET`	The Google button stays hidden.	Create an OAuth client in Google Cloud. Redirect address: `<CONVEX_SITE_URL>/api/auth/callback/google`. Set both on Convex.
Sentry: `VITE_SENTRY_DSN`	No error tracking.	Create a Sentry project and set this on Vercel, then rebuild. It is read at build time.
Caps: `LEARNER_DAILY_USD_CAP`, `AI_DAILY_USD_CAP`	USD 0.05 per learner and USD 0.50 in total per day.	Set both on Convex. Measure real cost per tool first if you can.
Lawyer	The privacy notice and terms show "Draft for legal review" on the page.	Have both read. They describe what the app does and claim compliance with no law.
Live red team	Only the mock run has been done.	Run `pnpm redteam --cap 0.10` on the local backend with your OpenRouter key, before under 18s use the app.
Social image: `/art/og-default.webp`	Link previews have no picture.	It comes from Codex's art batch. Some link preview crawlers may not read WebP; this could not be tested without a deploy.

Exact settings are in `docs/DEPLOY.md`. The Vercel protection noted there on 29 October also has to be off before learners can reach the site.

What changed

	Item	What it does now
1	Link reader	Follows at most 3 redirects, checks each one, and blocks private addresses at the moment of connecting.
2	Email codes	Email verification and password reset by code, sent through Resend. Admin access needs a verified email.
3	Google sign in	Built, and hidden until its keys exist.
4	Guardian consent	Needs a 6 digit code sent to the guardian's phone. The link stays. Limits on sends and tries.
5	Spending caps	USD per learner per day replaces call counts, plus the deployment cap. Cost recorded per tool, alert rows at 50 and 80 percent, friendly limit messages, several model ids per tier.
6	Second opinion	A fast model checks Taku's ideas and marking schemes. Rejected items are dropped. If the check fails to run, items are marked not checked.
7	Maths	KaTeX and chemistry in answers, cards, papers and print. Prompts now ask for LaTeX between $ signs.
8	Widgets	Taku supplies data, the app draws it and its own code marks each step. Equation steps, fill in the blanks from notes, long division. In Guide me answers and the Study tools tab.
9	Chat composer	No longer covers the intro or starter chips at 360 by 640.
10	Sign out	Moved to Settings. Screens that cannot reach Settings keep their own button.
11	Progress	Chat replies arrive as they are written. Notebook answers show Reading your notes, Writing your answer, Checking quotes.
12	Notebook on phones	Ask Taku first. Sources and settings sit in a sheet behind a Sources button.
13	First run checklist	Add notes, Ask one question, Make flashcards, on home, read from what the learner has done.
14	Style picker	A compact version in Settings.
15	Landing	Open Graph and Twitter tags, and the copy is in the page's HTML for crawlers. The build fails if it goes missing.
16	Sentry and counts	Sentry is off when unset and strips personal data. Feature counts stay in our own database, off by default, and are never used for under 18s.
17	Privacy and terms	Public draft pages, based only on what the code does.
18	Red team	A script for answer leaks, companion requests and unsafe topics. Mock in CI, live only with a spending cap.

I also added a CI workflow (`.github/workflows/ci.yml`): lint, typecheck, tests, mock red team and build on every push. Its first run, on this commit, passed. Browser journeys do not run in CI, because they need a local backend. Printing a paper also used to include the sidebar and tab bar; that is fixed.

What a security review found

I ran a read only security review on the auth, consent, link and cap code before committing. It found these. The first four changed the code, and tests cover those changes:

- **High, narrowed but not closed:** many calls at once could all pass the cap, because cost is only known after the model answers. A learner can now start 12 things a minute, or 20 for reading photos. They can still pass the cap by what one minute of starts costs, and many learners together can pass the deployment cap by a little.
- **Medium, fixed:** a guardian who gave, withdrew and gave again could not withdraw a second time.
- **Medium, fixed:** a hostile web page could burn server time in the HTML reader.
- **Low, fixed:** a bad character code on a page could leave a link source stuck on reading.
- **Open, your decision:** the phone code proves someone holds a phone, and proves nothing about who they are. The learner holds the link, so a learner could type their own number and consent for themselves. Decide how to handle this before adding the real provider.

What has not been tested

- **Any real model.** Widget prompts, second opinion quality and LaTeX in real answers have only run against replies I wrote by hand. The mock red team shows the app routes those replies correctly and says nothing about what a real model would do.
- **Real senders and sign in.** The Resend sending code, the Google flow and Sentry have never reached the real services.
- **Real cost.** Costs in mock mode are modelled. The USD 0.05 cap has no measurement behind it.
- **Anything in production,** including link previews and the first deploy of the new schema.
- **Held answers.** Guide me relies on the prompt not to give the answer away. No filter on the output was added; that is still Phase 5.

The audit findings were not pasted into the brief, so I read the audit PDF from the other worktree for context and built the numbered list as the scope. Findings outside that list were not worked on. Decisions and sources are in `DECISIONS.md`. The commit has no co author line, because you asked for no model identifiers in commits.

How to roll back

The tag `checkpoint-before-mvp` marks commit `bb8677b`, the state before this work. History was not rewritten, so the safe way back is a revert commit:

```
git revert a54d2f6
git push origin main
```

To only look at the old code:

```
git switch --detach checkpoint-before-mvp
```

Production needs no rollback today, because this version has not been deployed. If it is deployed and later reverted, Convex may refuse the old schema, because stored rows would hold fields the old schema does not list. In that case keep the new schema and revert only the rest.